

Internet Engineering Task Force (IETF) B. Simpson Internet-Draft
C. Simpson Intended status: Standards Track HumanKey Project
Expires: January 1, 2026 June 30, 2025

Human-Mediated Mutual-Handshake Authentication
draft-simpson-human-mutual-handshake-00

Abstract

This document specifies a simplified protocol for mutual, human-mediated authentication between two parties using Time-based One-Time Passwords (TOTP) and asymmetric cryptographic key exchanges. The protocol explicitly requires human mediation both during the initial key exchange and at authentication time, ensuring secure, human-centric authentication without relying on persistent online connectivity or centralized identity authorities.

Status of This Memo

This Internet-Draft is submitted in full conformance with the provisions of BCP 78 and BCP 79.

Internet-Drafts are working documents of the Internet Engineering Task Force (IETF). Note that other groups may also distribute working documents as Internet-Drafts. The list of current Internet-Drafts is at <https://datatracker.ietf.org/drafts/current/>.

Internet-Drafts are draft documents valid for a maximum of six months and may be updated, replaced, or obsoleted by other documents at any time. It is inappropriate to use Internet-Drafts as reference material or to cite them other than as "work in progress."

This Internet-Draft will expire on January 1, 2026.

Copyright Notice

Copyright (c) 2025 IETF Trust and the persons identified as the document authors. All rights reserved.

This document is subject to BCP 78 and the IETF Trust's Legal Provisions Relating to IETF Documents (<https://trustee.ietf.org/license-info>) in effect on the date of publication of this document. Please review these documents

carefully, as they describe your rights and restrictions with respect to this document.

Table of Contents

1. Introduction

Digital systems have long conflated identity and trust, binding both to centralized credentials and persistent institutional records. In contrast, HumanKey introduces a model where identity and trust are each defined ephemerally - emerging only through voluntary, human-mediated interaction. By separating authentication from institutional validation, the protocol enables users to express identity temporarily and to grant or revoke trust dynamically, mirroring the lived flexibility of real human relationships.

As identity spoofing and impersonation threats continue to grow, especially in remote or low-connectivity environments, new approaches are needed for mutual authentication that place trust back into the hands of individuals. This document describes a lightweight, decentralized authentication protocol that combines Time-based One-Time Passwords (TOTP) with human mediation at two critical junctures: the initial cryptographic key exchange, and each real-time authentication event.

The protocol provides peer-to-peer authentication that avoids institutional or cloud-based intermediaries, allowing users to establish and validate trust directly. It leverages asymmetric cryptography to securely exchange per-relationship secrets and requires both parties to actively participate in the verification process using any band of communication they deem appropriate.

In environments where connectivity is intermittent or fully offline, the protocol supports deferred log synchronization and maintains verifiable logs of all trust events. These characteristics make it suitable for secure interpersonal authentication across civil, operational, and field settings.

Human relationships are inherently dynamic: bonds may strengthen, weaken, or reemerge across time and context. The HumanKey protocol embraces this natural flexibility by enabling a persistent cryptographic relationship whose

trust state is inherently ephemeral and human-mediated. Much like an elastic thread woven into fabric, HumanKey provides subtle elasticity in the structure of interpersonal trust – allowing it to stretch, tighten, or relax without breaking. It supports durable memory of prior trust while permitting effortless revalidation or graceful expiration, aligned with the humans' own choices rather than institutional dictates. This architecture restores autonomy, adaptability, and direct agency to participants in digital authentication.

Identity is what's presented; trust is what's granted in response.

But in HumanKey, these are fused: Your persistent keypair is an identity anchor. Your TOTP code exchange activates trust. When both are human-mediated and optionally time-bound, the system supports ephemeral trust, and pseudo-ephemeral identity.

By not binding identity to an institution, HumanKey enables a kind of super-self-sovereign, elastic identity that can:

- Persist for decades or
- Be dropped tomorrow with no external trace

This creates a space where identity itself can be ephemeral, revocable, and unlogged, unless humans choose to retain or synchronize it.

2. Terminology

The following terms are used throughout this document:

- Ephemeral Trust: A persistent cryptographic relationship whose active trust state is subject to voluntary, human-mediated revalidation. While the underlying keys may persist indefinitely, the trust they enable adapts dynamically – expiring, renewing, or reawakening based on human behavior rather than automated systems. This mirrors the flexible, durable, and sometimes dormant nature of human relationships.

- Ephemeral Identity: A temporary, context-specific digital persona formed through the presentation of a unique keypair and voluntary interaction. While a keypair may persist, the identity it represents is not inherently linked to a broader account or institution, allowing individuals to present themselves anew in each relationship. Ephemeral identity supports privacy, minimization, and human-centered negotiation of recognition.
- Initiator: The party who begins the authentication process or initiates a relationship request.
- Responder: The party who receives a request to authenticate or form a relationship.
- TOTP (Time-based One-Time Password): A short-lived code generated from a shared secret and the current time, as specified in RFC 6238.
- Public Key / Private Key: Asymmetric keypair used to encrypt and decrypt the TOTP secret during initial key exchange.
- Human-Mediated Channel: Any trusted, real-time communication medium between users, such as a phone call, video call, or in-person meeting.
- Authentication Session: A bounded time window during which two parties confirm each other's identities using shared TOTP codes.
- Local Trust Log: A secure, timestamped record of authentication and trust events, retained on the user's device.

3. Protocol Description

3.1. Initial Key Exchange (Human-Mediated)

To begin a secure relationship, the Initiator (User A) generates a new asymmetric keypair unique to their interaction with the Responder (User B).

1. Key Generation: User A creates a public/private keypair for use exclusively in the relationship with User B.
2. Public Key Sharing: User A provides their public key to User B through a mutually acceptable and verifiable channel. While the protocol supports human-mediated methods (e.g., direct conversation, video, or trusted introduction), it also accommodates asynchronous or delegated exchanges, provided both parties can evaluate the trustworthiness of the source.
3. TOTP Secret Generation: User B generates a new TOTP secret specific to User A.

4. Secret Encryption: User B encrypts the TOTP secret with User A's public key.
5. Secret Transmission: Via the same human-mediated channel, User B transmits the encrypted TOTP secret to User A.
6. Secret Decryption: User A uses their private key to decrypt and store the secret.

This process is then repeated in reverse, enabling both parties to hold a TOTP secret created by the other. Each party thus gains the ability to validate the TOTP codes generated by their counterpart.

3.2. Authentication Event (Human-Mediated)

Once a mutual relationship is established and both parties hold TOTP secrets generated by the other, authentication can be performed as needed using human-mediated communication.

1. Session Initiation: Either user (Initiator or Responder) proposes an authentication session through a real-time human channel such as a phone or video call.
2. Code Generation: Each user uses the TOTP secret they received during key exchange to generate a current code.
3. First Exchange: User A verbally communicates their generated TOTP code to User B.
4. First Validation: User B manually enters the received code into their device and validates it against the expected value.
5. Second Exchange: User B then communicates their own TOTP code to User A.
6. Second Validation: User A manually enters and validates the code.

If both codes are validated successfully, mutual authentication is confirmed. The result may optionally be recorded in the local trust logs and considered valid for a predefined duration.

3.3. Offline Operation and Logging

The protocol is designed to function even when no internet or centralized infrastructure is available. Users may perform mutual authentication offline by leveraging previously exchanged TOTP secrets.

1. Cached Secrets: Each party stores the TOTP secrets locally on their device.

2. Manual Session: Authentication proceeds as normal using a phone call or in-person exchange, with each party generating and validating TOTP codes.
3. Event Logging: Each device logs the authentication event with a timestamp, directionality (who initiated), and validation results.
4. Deferred Sync: When connectivity is restored, logs can be uploaded and merged with a central or shared trust record. Cryptographic signatures ensure consistency and prevent tampering.

This offline capability supports robust use in low-resource, high-security, or field settings where connectivity is unreliable or delayed.

4. Optional Extensions

This section outlines enhancements to the core protocol that may be implemented to improve flexibility, session control, and lifecycle management.

1. Session Duration Customization: Authenticated sessions may allow custom durations beyond the default (e.g., extend to 30 minutes) if both users consent.
 2. Manual Session Termination: Either user can terminate an active session at any time, prompting immediate expiration of mutual trust.
 3. Trust Revocation Mechanism: Users can revoke trust relationships individually or globally by issuing signed revocation messages. These can be propagated upon next sync.
 4. Session Metadata: Users may optionally include structured metadata with authentication sessions (e.g., purpose, location, tags), appended to local logs.
 5. Audit Hooks and Export: Implementations may support exporting signed trust logs for third-party audit or integration with external security infrastructure.
- #### 5. Auditable Record

Every authentication event, whether online or offline, is logged locally by each participant in a tamper-evident format. These logs include:

- Timestamp of the authentication event.
- Role of the user (Initiator or Responder).

- Result of each TOTP validation step (success or failure).
- Optional metadata (if supported and enabled).

Local trust logs are cryptographically signed to ensure integrity and can be verified upon synchronization or audit. When connectivity becomes available, these logs can be merged with a shared repository, enabling:

- Reconciliation of mutual records.
- Dispute resolution and forensic analysis.
- Rebuilding a verifiable trust graph across relationships.

Audit transparency is a core design goal. Each log entry serves as a cryptographically provable assertion of interaction, supporting trust without institutional oversight.

6. Security Considerations

This protocol assumes the integrity and authenticity of the human-mediated communication channel used for key exchange and TOTP code sharing. Any compromise of this channel (e.g., social engineering, man-in-the-middle attacks during verbal exchange) could lead to impersonation or key leakage.

To mitigate risks:

- Users should confirm identities via secondary trusted methods before accepting keys or TOTP codes.
- Devices must securely store keys and secrets and restrict access to trust logs.
- TOTP codes are ephemeral by design, limiting the window of exploitation.
- Cryptographic signing of all logs ensures tamper detection.

The protocol deliberately omits automated validation or reliance on centralized authorities, trading scalability for trust rooted in human verification. Implementers must ensure proper user interface design and user education to prevent misinterpretation or misuse.

7. Interoperability Considerations

To facilitate cross-implementation compatibility and ensure coherent operation among HumanKey clients, the following interoperability dimensions are identified and recommended for profile alignment:

TOTP Profile

All implementations should adhere to a shared profile of [RFC6238]:

- Hash function: SHA-256
- Time step: 30 seconds
- Digits: 6
- Encoding: TOTP secrets MUST be Base32 encoded as per [RFC3548].

This profile, informally referred to as TOTP-HK-1, ensures consistency in code generation and validation across clients.

Key Representation

To support interoperable key sharing, implementations SHOULD support:

- Ed25519 for public key cryptography (see [RFC8410]).
- Public key serialization via [RFC7468] (PEM) or [RFC7517] (JWK).
- Consistent canonicalization of public keys for fingerprinting and trust log referencing.

Log Format

Implementations MAY optionally export signed trust logs for verification or audit. To support interoperability:

- Logs SHOULD be serialized as structured JSON objects.
- Each event SHOULD include:
 - timestamp (ISO 8601)
 - session_id (opaque string)
 - role (initiator | responder)
 - outcome (success | failure)
 - signature (detached or embedded)

Future versions may define a schema under a humankey-log media type.

Revocation and Synchronization

To support synchronization of revocation events or session results, clients MAY adopt a portable message format containing:

- Public key of sender
- Hash or ID of the target session
- Timestamp
- Optional revocation reason
- Signature of sender

These messages MAY be exchanged over federated or peer-to-peer sync protocols, but MUST be independently verifiable via digital signature.

URI Format for HumanKey Exchanges

To enable QR-based handshakes or web-based introductions, implementations MAY support a URI format of the following form:

humankey://exchange?pubkey=...&label=...&expires=...

Where:

- pubkey is a base64 or Base58 encoded public key
- label is a human-readable identifier
- expires is an optional ISO timestamp

This allows ephemeral identity presentation in constrained channels.

8. IANA Considerations

This memo includes no request to IANA.

9. References

[RFC6238] M'Raihi, D., Machani, S., Pei, M., and J. Rydell, "TOTP: Time-Based One-Time Password Algorithm", RFC 6238, DOI 10.17487/RFC6238, May 2011, <https://www.rfc-editor.org/info/rfc6238>.

Authors' Addresses

Bobby Simpson HumanKey Protocol 801 South Broadway Shawnee, OK
74801 United States

Email: humankey@bobbysimpson.com

Campbell Simpson HumanKey Protocol 1441 NW 92nd Street Oklahoma
City, OK 73114 United States

Email: humankey@campbellsimpson.com